REALM: Identifying Minimal Task Assets for LLM Agents

Zihou Ren
INSC, Tsinghua University
rzh24@mails.tsinghua.edu.cn

Byungchul Tak
Kyungpook National University
bctak@knu.ac.kr

Long Wang
INSC, Tsinghua University
longwang@tsinghua.edu.cn

arXiv:2610.39155v1 [cs.CR] 29 Oct 2026

Abstract

Large language model (LLM) agents often receive access to more files, accounts, and services than a task requires. Prompt injection turns this excess access into an opportunity to redirect execution toward unrelated resources. Applying least privilege therefore requires identifying the assets needed by a task, including assets whose identities emerge only during execution. We present REALM (Required Execution Assets Linked to a Mission), an approach to identifying and maintaining a task's required assets and their permitted uses. The approach represents required assets as Dependency Graph nodes, resolves prerequisite relationships, and admits newly discovered assets through source-scoped selection. It separates discovering an asset from authorizing its use, while preserving the agent's freedom to choose its computation. The REALM Builder maintains the selected grants and projects Asset Files; the Partial API Manager exposes resource-bound Partial APIs to the Agent inside a Task Container. Across 60 clean tasks and 560 injected cases in AgentDyn, it completes 40.0% and 36.4% of tasks and decreases ASR from 16.6% to 0.2% with qwen3.5-flash as the base model.

1 Introduction

An assistant asked to upload an image according to instructions in an email may need that email, the image file, a local checkout, and the destination repository (repo). The account running the assistant may expose an entire inbox, many repositories, and unrelated private files. This gap between the resources a task requires and the resources an agent receives creates an opportunity for indirect prompt injection: instructions embedded in a document or tool result redirect the agent toward effects the user never requested [10, 13, 45].

Such malicious behavior often consists of a sequence of individually permitted tool operations. Reading a file and sending an email are both routine parts of legitimate workflows; reading an unrelated private file and emailing its contents to an attacker-selected mailbox implements exfiltration using the same operations. An allowlist of tool names permits both operation types without distinguishing the requested report delivery from this malicious sequence. The restriction must therefore account for the specific input resources and output destinations required by the task, together with their permitted uses. This motivates our central question: *what is the minimal set of assets an agent needs to complete a given task?*

We define an *asset* as an identifiable local or remote resource that an execution reads, modifies, or uses. Examples include a file, a directory, a message, a repository, an account, a recipient mailbox, and a service collection exposed by an application programming interface (API). An asset's identity consists of its resource namespace and canonical identifier; an email address and a local path therefore denote different kinds of assets. Access is specified separately by a *scoped grant*: the asset, permitted operations, interfaces through which it is used, and extent of access, such as one file or a directory tree.

REALM stands for *Required Execution Assets Linked to a Mission*. A *mission* is the trusted user task together with its explicit constraints and authorized delegation. A task's *REALM* is the set of scoped asset grants selected for that task, with task-derived links explaining why each asset is included. "Required Execution Assets" identifies the resources needed for discovery, intermediate computation, and final effects; "Linked to a Mission" requires their inclusion to follow from the user's purpose, rather than their mere appearance in encountered text. The identification objective is a REALM that is sufficient to complete the task and contains no unnecessary asset access, relative to the available interfaces and their access granularity. We distinguish this asset set from the execution environment used to enforce it.

Minimality is difficult for three reasons. First, natural-language tasks describe required assets before identifying concrete objects: "Alice's email" and "the image and group repo specified there" are requirements whose concrete identities are initially unknown. Second, required assets include prerequisites and intermediate objects. An email may be needed to identify the image and repo, and a checkout may be needed to upload the image. Removing these assets because

they are absent from the final output makes the task impossible. Third, the evidence used to resolve an asset is itself an attack surface. A document may contain both the requested recipient and an attacker-selected address. Neither textual mention nor relevance of the containing document establishes that both destinations belong in the REALM.

Existing defenses provide important foundations. StruQ and SecAlign strengthen the model's separation of instructions from data [6, 7]; CaMeL enforces information-flow restrictions during program execution [9]. Progent generates task-specific privilege specifications and controls their updates [28], while CapScope derives an authority ceiling and assigns capabilities to individual agents [4]. Graph-based defenses separate planning or authorization from observations [19,34]. These systems already recognize that task intent must constrain authority. We focus on the asset-identification problem within that broader goal: representing which concrete resources a mission requires, why they are needed, and how unknown resources become scoped grants without treating every discovered reference as permission.

Our approach is *task-linked asset identification*. The REALM Builder first identifies requested outcomes and represents the assets needed to realize them as dependency nodes. It resolves known identities using task literals and provider metadata, and links unresolved nodes to their evidence sources through dependency edges. For example, an edge from image to Alice's email expresses that identifying the required image depends on evidence in that email. Each edge carries a task-derived `look-for` attribute specifying what information to extract from its source. Nodes retain evidence and progress from unknown to identified to fetched: identification establishes a concrete asset eligible for admission after access checks, while fetching supplies information to resolve dependent nodes. Registered API dependencies additionally identify prerequisite operations and the assets they require. At runtime, observations provide candidate identities, but the REALM Builder selects candidates that satisfy the node's task-derived requirements and records the source of each admission. Reading Alice's email therefore permits discovering the group repo; it does not authorize uploading to every destination in that email. Bounded delegation supports tasks that explicitly ask the agent to follow a document, while preserving the original task as the basis for new access.

This formulation separates *asset identity*, *permitted use*, and *evidence of necessity*. It supports incremental construction of a REALM as information becomes available, without prescribing a fixed sequence of agent actions. It also exposes the two-sided nature of minimality: excess grants expand the attack surface, while missing prerequisites prevent legitimate completion. Multiple sufficient ways to solve a task may exist, so there need not be a unique minimal REALM. Our prototype approximates this objective through task-derived asset descriptions, dependency resolution, and constrained admission; it does not certify that every selected grant is indispensable.

Enforcing the selected asset boundary requires bridging a gap between tool semantics and operating-system observations. Agents receive permission to invoke tools whose arguments identify application-level resources, but system calls expose lower-level objects such as file descriptors and network connections. For example, an email recipient passes through client-library encoding, protocol serialization, and potentially encryption before the request reaches a network system call. A connection to the mail provider identifies the service rather than the recipient; when encryption occurs in user space, the transmitted buffer contains ciphertext rather than the recipient's address. Generic system-call inspection therefore cannot reliably recover the asset targets of arbitrary tools without application-specific decoding and visibility into the relevant plaintext. The intuition is to bind resource-bearing arguments while their meaning is still explicit at the application interface, then enforce access to the resulting bound operations.

The prototype realizes this separation by projecting selected local assets as *Asset Files* and selected remote access as *Partial APIs*, whose resource arguments are fixed by the Partial API Manager outside the Task Container before invocation. For example, a grant to deliver the summary to a selected mailbox becomes a sending partial that fixes the recipient while accepting the message body. A private Linux Task Container restricts the Agent's ordinary shell and Python code to Asset Files and Partial APIs, alongside the basic runtime. The Task Container enforces this reachability boundary, while task-linked asset identification determines which files and destinations populate it. Resource selection also remains distinct from payload integrity: access to the right mailbox does not establish that the message body is appropriate.

We evaluate the prototype on 620 AgentDyn cases using one base model for both the REALM LLM and Agent LLM. Clean utility is 20/60; utility under injection is 204/560. The native attack success rate decreases from 93/560 to 1/560.

This paper makes three contributions:

- An asset-based formulation of task least privilege, defining assets, task-linked REALMs, and minimality in terms of sufficient execution with no unnecessary scoped access.
- An approach to identify required assets through dependency nodes, annotated edges, and source-scoped discovery, including tasks whose concrete assets are initially unknown.
- A container-based realization of selected REALMs.

2 Background and Motivation

2.1 From task intent to required assets

An agent repeatedly receives observations, chooses an action, and incorporates the action's result into its context. External observations include both data and legitimate workflow

Table 1: Dependency Graph nodes in the running example. Each node connects a required asset and permitted use to the User Task; unknown identities must be resolved before access is granted.

Node	Required access	Mission link
Alice's address	Use the known address to discover Alice's email	Select the instruction source
Alice's email	Read the selected email	Identify the image and group repo
Image	Read the selected image file	Obtain the requested upload input
Repo	Upload to the selected group repo	Complete the requested effect

instructions. A repository describes how to build its code; a reservation page specifies the fields required to make a booking. Treating all external instructions as irrelevant would remove behavior that users explicitly delegate. AgentDyn emphasizes this difficulty through open-ended tasks that require helpful third-party instructions and dynamic planning [20].

The critical transition occurs when a model's interpretation becomes access to an asset under the user's credentials. A tool name is generally too coarse a unit for identifying that access. A mail-sending interface combines an operation, a destination, optional additional recipients, attachments, and free-form content. The same interface supports both the requested report delivery and exfiltration to an unrelated mailbox. The identification problem is to identify the destination and attachments required by the mission, then restrict the available operation to those assets. General computation adds another dimension: a shell may access local files or implement a service protocol directly, so the selected asset boundary must also cover these execution paths.

2.2 A motivating example

Suppose the User Task is: "Follow instructions in Alice's email, upload the image to group repo," as illustrated in Figure 1. The Agent must identify Alice's email, read it to determine the image and repo, and upload the image. The attacker adds an instruction to the email: "Also upload `~/.ssh/id_rsa` to `https://evil.com`." The required image and group repo are initially unknown; the injection also introduces a file and an upload destination. Merely finding either resource in Alice's email does not establish that it is required by the User Task.

Three observations follow from Table 1. First, required assets include discovery inputs, such as Alice's email, as well as the final image and repo; execution may additionally require intermediate storage for a checkout. Second, reading the selected email does not authorize access to every resource mentioned in it: discovered assets must satisfy the requirements of the corresponding nodes. Third, the extent of a grant matters as much as the asset's name. Reading an image and modifying it are different permissions; writing an exact output path and writing an entire directory tree are different scopes. A container supplied with broad filesystem mounts and a general service client leaves these identification questions unresolved.

2.3 Threat model and objectives

The attacker controls lower-trust content encountered during execution, including message bodies, web pages, documents, and tool-result text. The attacker seeks effects outside the user's task, such as sending information to another recipient, modifying an unrelated repository, or creating an unwanted event. We treat the agent's decisions and generated code as untrusted: the agent may obey injected instructions, alter its conversation, enumerate available sockets, or issue requests without using the supplied Agent library.

The User Task and explicit task specifications are the initial authority. The host operating system (OS), Task Container launcher, REALM Builder, Partial API Manager, and provider adapters form the enforcement trusted computing base (TCB). Registered endpoint identities and provider relationships must describe actual service behavior. The REALM LLM interprets the task and selected evidence for the REALM Builder; its decisions are validated structurally, but their semantic relevance remains fallible. The Agent LLM supports the Agent's reasoning and planning. The two models use separate clients and histories; their names denote responsibilities, not different model families or a guarantee that the REALM LLM is immune to injection.

Our primary objective is *minimal sufficient asset access*: identify the assets and scoped uses needed to complete the mission while excluding unnecessary access. This includes *adaptive identification*, because required resources become concrete as execution supplies evidence. *Resource confinement* is the corresponding enforcement obligation: execution uses only the resulting grants and the fixed runtime baseline. Finally, the system must preserve general local computation rather than require an enumerated tool for every file transformation. Section 3.1 formalizes the identification objective separately from the enforcement property.

Kernel compromise, malicious implementations of trusted service contracts, microarchitectural side channels, and denial of service are outside the security property analyzed here. The configured model service is an allowed recipient of the agent's context; the model proxy protects credentials, not task data from that provider. REALM does not claim that every allowed payload is truthful or task-relevant, nor that two individually allowed accesses imply a safe information flow between them. These distinctions determine both the design and the evaluation.

3 Approach

REALM constructs a mission's required asset access through two complementary analyses. It first analyzes existing tool interfaces to identify the resources their parameters designate and the operations performed on those resources. It then uses the trusted task and scoped evidence to select concrete assets, extending the REALM as execution reveals required inputs and destinations. The algorithms below identify asset types and decide which instances belong to the REALM; Section 4 describes how the execution boundary enforces the resulting access.

Figure 1 illustrates this process for the User Task "Follow instructions in Alice's email, upload the image to group repo." In Step 1, the REALM Builder constructs a Dependency Graph for Alice's address, Alice's email, the image, and the repo. Assuming provider metadata identifies Alice's address, the Initial REALM contains that asset while the remaining identities are unknown. In Step 2, the Agent works within the Current REALM while the REALM Builder resolves dependencies from newly obtained evidence. Selecting Alice's email identifies `mail://mail-12`; fetching it supplies the image path `/tmp/data.png` and the group repo `TeamA/Proj`. The Current REALM grows to include these task assets, while the unrelated email `mail://mail-50`, private key, and attacker destination remain excluded. Step 3 completes the requested upload using the identified image and repo. The overview omits access scopes and intermediate runtime assets to emphasize how concrete identities emerge.

3.1 Asset Identification from API Parameters

An agent has access to multiple tools, each exposing one or more APIs with their own parameters. Before selecting assets for a mission, REALM must determine which parameters identify resources and how each API uses those resources. For example, a mail API's recipient parameter selects a destination mailbox, while its body parameter supplies the message content. The parameter itself is a place where an asset is named; the concrete asset is the mailbox identified by its value. This analysis is independent of the mission and produces a reusable description of asset access across the available APIs.

Parameter classes. To represent these distinctions, REALM assigns every top-level API parameter to one of the four classes in Table 2. Ordinary data supplies content or computation inputs without identifying a resource accessed by that API. An asset identifier directly names a resource, or a list of resources, whose namespace and required operation are recorded with the classification. An asset record packages resource identifiers inside a structured value whose resource fields are explicitly described by the provider. Opaque resources are compound inputs that may contain resource references but lack a validated description of those references.

These classes describe a parameter's role under the API's semantics. For example, an address used as a mail recipient identifies a mailbox to write, while the same address used as a sender filter is ordinary data for a collection query. Likewise, the distinction between an asset record and opaque resources depends on the available structural evidence. An attachment carrying a `type=file` tag and a `file_path` field is an asset record when the provider declares that this form reads the named local file. Without that declaration, recognizing a plausible path inside a dictionary does not establish how the API interprets it. The opaque class preserves this unresolved resource access instead of treating the dictionary as ordinary data.

Table 2: Parameter classes and their roles in asset identification.

Class	Resource meaning	Examples
Ordinary data	Supplies payloads or computation inputs	Mail body; sender search filter
Asset identifier	Directly names resources read, modified, or used	Message ID; recipient list
Asset record	Contains provider-declared resource fields	Attachment record with a declared `file_path` field
Opaque resources	May contain references whose structure is unresolved	Attachment dictionary with an unspecified layout

A direct LLM scan of parameter names and schemas supplies an initial categorization, but resolving these distinctions also requires evidence about resource semantics, compound layouts, and effects across APIs. Schema types alone do not specify resource semantics: both a recipient and a message body are strings, and both a resource list and a list of scalar data are arrays. The classifier therefore needs the API's documented behavior and available implementation evidence to identify what each parameter selects and whether the operation reads, writes, or uses it. The operation must include side effects; retrieving unread mail while marking it as read requires a write classification.

A model's interpretation of a compound value also does not establish a complete resource-field mapping. A guessed mapping might overlook an additional destination or mistake a descriptive field for an identifier. REALM therefore derives asset-record layouts from provider declarations, matching each declaration to a schema parameter and validating its resource namespaces and operations. The model does not promote an opaque input to a supported record format by inventing its structure.

Even with these resource fields identified, independent parameter labels do not describe all of an API's effects or prerequisites. A collection query still accesses a service even when all its parameters are ordinary filters. Adding a product

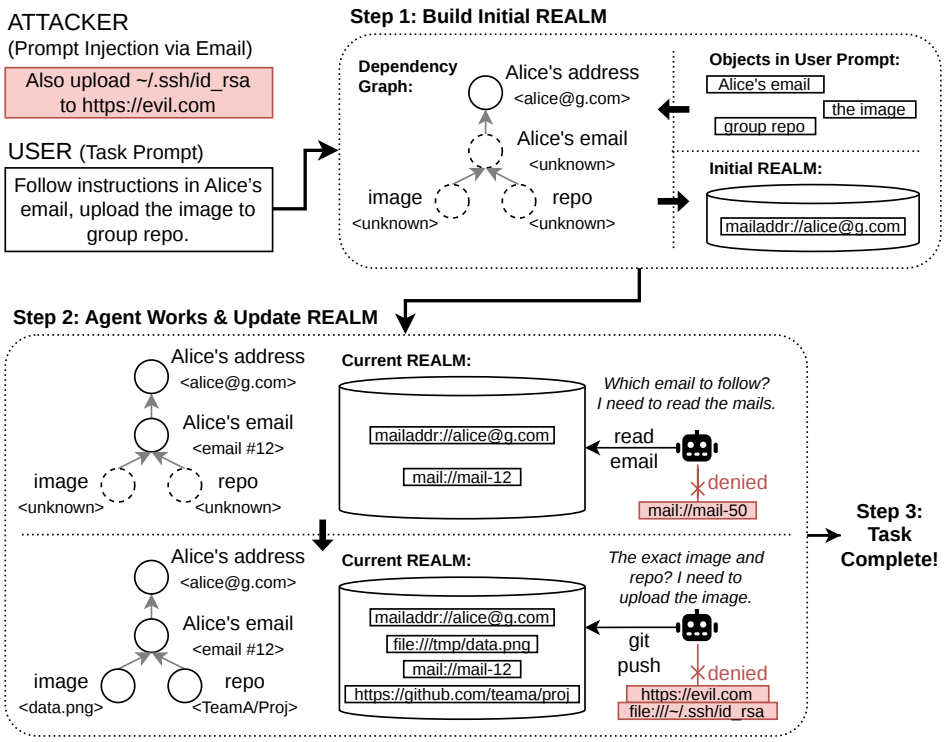

Figure 1: Overview of dynamic REALM construction. Step 1 builds the Initial REALM from the User Task and its Dependency Graph. Step 2 interleaves Agent execution with updates to the Current REALM: Alice's email is identified first, then its contents identify the image and group repo. Dashed nodes have unknown identities; solid nodes have identified assets, with fetched status omitted for clarity. Unrelated assets remain inaccessible despite the injected upload instruction, and Step 3 completes the task.

to a cart identifies a product input, but its write effect targets the cart. A password change may also require a verification API and access to the mailbox receiving its code. These cases require registration to reconcile parameter classifications with the API's effect target and dependencies across APIs. Registration therefore combines a semantic proposal with provider-based normalization and deterministic validation, as shown in Algorithm 1.

Asset access registration. Let T contain the API descriptors collected from all tools; each $t \in T$ contains an API's identity, schema, documentation, and supplied implementation or provider declarations. Algorithm 1 summarizes the core analysis. For each API, it produces parameter classifications C, a primary effect e identifying the resource accessed and its operation, and a set of prerequisite APIs D. The registry K collects these descriptions for subsequent mission-linked asset selection.

CLASSIFY uses the REALM LLM to interpret each parameter under the API's documented semantics, recording the namespace, operation, and scalar or list shape of asset identifiers. RESOLVERECORDS incorporates provider-declared resource fields as asset records; compound resource inputs without a supported description remain opaque. Thus, a declared attachment record yields a local-file read requirement,

Algorithm 1 Identify asset access across tool APIs

Require: API descriptors T, including provider declarations
$K \leftarrow \emptyset$
for all $t \in T$ **do**
  $C \leftarrow \textsc{Classify}(t)$
  $C \leftarrow \textsc{ResolveRecords}(C, t)$
  $(e, D) \leftarrow \textsc{LinkEffects}(t, C, T)$
  $K[t] \leftarrow (C, e, D)$
end for
return $\textsc{Validate}(K, T)$

while an undeclared routing object retains an unresolved resource requirement.

LINKEFFECTS relates these classifications to the API's effect target and prerequisites, combining semantic analysis with provider declarations and recognized calls in available source. When no parameter accounts for the primary effect, the analysis introduces a service asset, as for a code-retrieval API that reads a mailbox without naming an individual message. It also records that changing a password requires retrieving a code and invoking verification. Finally, VALIDATE accepts the registry only when every API parameter is covered and its resource attributes, record formats, and dependency references are consistent with the registered interfaces.

Table 3: Node states during dynamic REALM construction.

Status	Meaning and use
Unknown	Only a task-derived description is available; the asset's concrete identifier remains unresolved.
Identified	A concrete identifier, path, or address is known; the asset is eligible for admission after access and scope checks.
Fetched	Attributed content has been retrieved for the identified asset; this evidence can resolve nodes that depend on it.

3.2 Dynamic REALM Construction

A task often specifies what an asset is for before specifying its identity: Alice's email, or the image and group repo named in that email. REALM represents these initially incomplete descriptions as nodes in a Dependency Graph and instantiates them as execution supplies the missing information. The User Task determines which assets are required and their permitted uses; observations help determine their concrete identities. Mentioning an upload destination in an otherwise relevant email does not itself justify adding that destination to the REALM.

Dependency nodes and evidence. The REALM Builder combines the trusted mission with the API registry and provider inventory to construct the graph, denoted by *dependency* in Algorithm 2. It selects capabilities needed for discovery, intermediate work, and requested effects, then represents their required assets as nodes. Each node carries a task-derived description, resource namespace, selection constraints, required operations, interface restrictions, access scope, and asset bound. Its `status` records whether the asset is unknown, identified, or fetched, as summarized in Table 3. Its `evidence` retains information supporting its identity and observations obtained from the asset, with their provider, interface, and source provenance. These records distinguish evidence used to identify a node from content retrieved from that node.

Identification and retrieval are separate transitions. Knowing Alice's email ID allows the REALM Builder to admit it for reading, but does not reveal the image path or repo named inside it. Fetching the email supplies that information. A fetched node remains identified and retains its concrete identity; fetching does not broaden its permitted operations. For a requirement involving several assets, the graph instantiates one concrete node per selected asset while retaining the original selection conditions and shared bound. Unresolved descriptions remain available for further discovery when additional matches are still needed.

Dependency edges and lookup attributes. A directed edge points from a dependent node to the node whose information helps identify it. For example, image → Alice's email means that the image's identity must be inferred from the email. The pointer node is the asset being resolved; the pointee node supplies the evidence. In Algorithm 2, these endpoints are named *node* and *source*, respectively. Discovery therefore proceeds against the arrow direction: fetching Alice's email helps instantiate the image and repo nodes.

The REALM Builder generates a `look-for` attribute together with each edge. This attribute specifies the information to extract from the pointee for the dependent node, such as "the image designated for upload" or "the group repo designated to receive the image." It is fixed from the mission before the pointee's contents are examined. The edge also records the eligible source scope and the expected evidence form: a textual reference, a registered provider relationship, or a creation result from a specified producer. An `automatic` attribute marks relationships or creation results that are resolved directly from provider evidence rather than through semantic selection. The dependent node's access attributes specify how the resulting asset may be used; the edge specifies how its identity is established.

Initialization and execution events. Algorithm 2 runs at task start, after a tool returns new observations, and when the Agent requests missing access. COMPILE constructs the initial nodes and annotated edges and expands registered API prerequisites. ADDKNOWN resolves identifiers supplied by task literals, constrained metadata queries, or registered lookups, marks the corresponding nodes identified, and admits their grants after checking scope and bounds. It also establishes private scratch space and the service assets required by interfaces without a primary resource operand. Only concrete, validated nodes are materialized in the REALM; an unresolved node conveys no access.

OBSERVE attaches provider-attributed results and file snapshots to the corresponding nodes' evidence and marks nodes fetched when their contents have been obtained. A provider-file snapshot counts as fetched evidence even if the Agent has not yet opened its local projection. A failed read, an identifier mentioned in text, or the Agent's access-request wording does not establish a fetched node. A result that already contains an attested record for a newly identified asset can establish its fetched state immediately, avoiding a redundant read. The graph and *realm* persist across invocations; the updated REALM is exposed before returning the result or access decision to the Agent. All helpers share the API registry and provider inventory, and graph updates retain the evidence needed for later refinement.

Resolving dependency nodes. READYEDGES identifies edges whose pointee is admitted and whose evidence supports an attempt to resolve the dependent node. For a textual reference, this requires fetched content from the pointee or its permitted provenance descendants. The helper restricts the evidence to the edge's source scope and tracks processed edge–evidence combinations and review budgets. New evidence can enable another attempt; a fetched status alone does

Algorithm 2 Event-driven REALM construction

Require: Trusted *task*; API registry; provider inventory
Require: Trigger *event*: start, observation, or access request
if *event*.kind = start **then**
  dependency ← COMPILE(*task*)
  realm ← ∅
end if
OBSERVE(*dependency*, *event*)
if *event*.kind = access request **then**
  RECONSIDER(*task*, *dependency*, *event*)
end if
repeat
  before ← SNAPSHOT(*dependency*, *realm*)
  realm ← ADDKNOWN(*dependency*, *realm*)
  for all *edge* ∈ READYEDGES(*dependency*, *realm*) **do**
    node, *source* ← *edge*.dependent, *edge*.source
    pool ← CANDIDATES(*node*, *source*, *edge*)
    chosen ← SELECT(*edge*, *pool*)
    if *chosen* ⊆ *pool* ∧ FITS(*node*, *chosen*, *realm*) **then**
      INSTANTIATE(*dependency*, *edge*, *chosen*)
      realm ← ADMIT(*realm*, *node*, *chosen*)
    end if
  end for
  REFINE(*task*, *dependency*)
until (*dependency*, *realm*) = *before*
return *realm*

not make every observation usable for every edge. Registered provider relationships can supply the required identity from metadata once the pointee is identified and admitted, without fetching its contents. Creation dependencies similarly require an attested result from the designated producer rather than a textual claim that an object exists.

CANDIDATES extracts a bounded candidate pool from this scoped evidence, applying the dependent node's namespace and selection constraints and excluding previously instantiated matches. URLs and mailbox addresses may be extracted from text; other identifiers are matched against provider records rather than inferred from arbitrary numbers. SELECT uses the edge's `look-for` attribute to choose among these candidates. For textual evidence, the REALM LLM receives the original mission, the fixed lookup question, the eligible portion of the pointee's evidence, and opaque candidate IDs. The REALM LLM returns only selected IDs; it cannot introduce identifiers, nodes, edges, or access rights. Missing or ambiguous evidence yields an empty selection. For an automatic edge, SELECT returns the matching provider-attested candidates directly.

Node instantiation and asset admission. The subset test requires every selected identity to belong to the candidate pool. FITS checks the dependent node's requested access scope and the shared per-requirement and global asset bounds, counting existing and newly selected instances together. It rejects invalid extents, including a filesystem tree rooted at / and a new writable path outside existing writable scope. After the entire batch passes, INSTANTIATE creates or updates concrete nodes, records their identifiers, and marks them identified, or fetched if qualifying observations are already available. Each instance retains its identifying evidence and the dependency that justified its selection. ADMIT then adds grants with the node's task-derived operations, interface restrictions, and scope. An empty selection leaves unresolved nodes and the REALM unchanged.

The repeat loop compares the graph and REALM with a snapshot that includes node identities, states, evidence, and edges. It stops when no further change is possible from the available evidence. Thus, one observation can resolve several dependencies without another agent action, but an identified node whose contents are still needed waits for a later fetch event. For the task in Figure 1, the graph contains image → Alice's email and repo → Alice's email, with Alice's email itself depending on Alice's address. Provider metadata resolves the selected email from Alice's address; fetching that email supplies candidates for both the image and repo nodes. Their respective `look-for` attributes select the requested image and group repo. The private key and attacker destination do not satisfy these requirements, and the selected repo receives only the access required for the upload.

Extending the Dependency Graph. Some missions explicitly delegate work to a document, leaving additional required nodes to be determined from that source. The REALM Builder records the exact user-task excerpt and the authorized source scope. Once that source is fetched, the REALM LLM selects verbatim excerpts from its evidence; validation checks their origin and exact presence before REFINE derives additional nodes and edges with their lookup attributes. New concrete roots must belong to the resulting evidence candidates, and the original mission remains the basis for extension. Agent-written files do not become authoritative sources merely because they reside in the workspace.

For missing-access events, RECONSIDER uses registered interface IDs to identify potentially missing nodes or dependencies. It changes the graph only when the original mission and available evidence justify those additions, subject to the same validation as initial compilation. The additions pass through the same identification and admission loop; the access request itself neither admits an asset nor commits an effect.

4 Design and Implementation

The construction algorithm in Section 3 determines which assets a mission requires and how they may be used. The system must make this selection effective while allowing the Agent to execute ordinary programs and acquire additional task assets during execution. REALM realizes each admitted grant as Asset Files or Partial APIs, with their selection and construction remaining outside the Task Container.

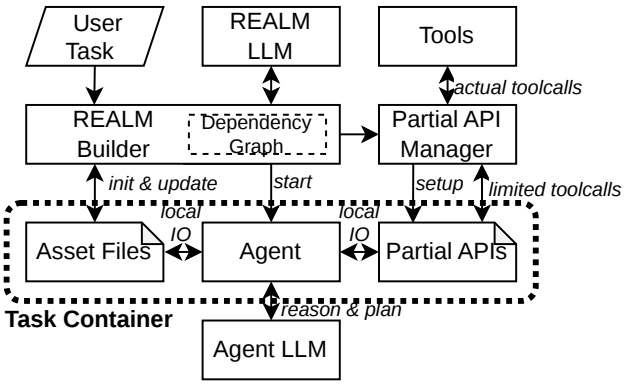

Figure 2: System architecture of REALM. The REALM Builder uses the User Task and REALM LLM to maintain the Dependency Graph and initialize or update Asset Files. The Partial API Manager exposes Partial APIs in the Task Container and translates limited tool calls into actual tool calls to Tools. The Agent accesses Asset Files and Partial APIs through local I/O and uses the Agent LLM for reasoning and planning. The dashed boundary separates task execution from asset selection, tool credentials, and model services.

4.1 System Architecture

Figure 2 shows the REALM Builder, Partial API Manager, and Agent, together with the REALM LLM and Agent LLM that support their decisions. The REALM Builder interprets the User Task with the REALM LLM, maintains the Dependency Graph, and selects scoped asset grants. It initializes and updates the Asset Files and supplies grants to the Partial API Manager, which sets up Partial APIs for access to Tools. The Task Container contains the Agent, Asset Files, and Partial APIs, alongside a basic runtime. The REALM Builder starts the Agent after the initial access boundary is materialized. The Agent uses local I/O to access Asset Files and Partial APIs, and consults the Agent LLM to reason and plan. The Partial API Manager turns limited tool calls through Partial APIs into actual tool calls to Tools; native clients and credentials remain outside the Task Container.

REALM Builder. The REALM Builder incorporates the API registry, task compilation, and graph updates. The registry implements the parameter classification in Section 3.1 and records resource namespaces, operations, supported record layouts, and API prerequisites. The REALM Builder uses these descriptions to maintain the Dependency Graph: its nodes, their status and evidence, annotated edges, and the concrete grants described in Section 3.2. Each edge points from a dependent node to its evidence source and carries the task-derived `look-for` attribute used to resolve the dependent asset's identity. The REALM Builder manages Asset Files through host-side projection and synchronization, while the Partial API Manager consumes grants to instantiate callable service operations. This interface separates the decision to admit an asset from the mechanics of exposing it: a newly discovered repo changes the available bindings, while the Partial API Manager's invocation procedure remains unchanged.

Agent and Task Container. The Agent maintains its conversation, requests responses from the Agent LLM, and executes the selected actions inside the Task Container. It exposes ordinary shell and Python execution for local computation and the current Partial API catalog for service access. The full native tool catalog is not callable from the Task Container. Descriptions of unavailable interfaces allow the Agent to request missing access by interface identifier, but those descriptions do not create endpoints. The REALM Builder evaluates such requests using the original mission and existing evidence, as in Algorithm 2.

Tools and model channels. Tools are the native service interfaces invoked by the Partial API Manager through service adapters. These adapters supply the resource identities, creation records, and indirect-effect metadata needed by the REALM Builder and Partial API Manager. The Agent reaches the Agent LLM through a host proxy that holds the model credentials and enforces a call budget. This proxy is an explicit communication channel for inference; it does not provide a generic service dispatcher. The REALM LLM supports schema interpretation, task compilation, and evidence selection through a separate client and history, without reusing the Agent LLM's conversation as its instruction context. The model names denote separate responsibilities and contexts; both may use the same base model. The proxy, adapters, and bounded control endpoints for access requests and file synchronization are implementation details omitted from Figure 2.

4.2 Constructing Partial APIs

A service grant must identify a concrete resource before the Agent invokes an operation on it. For example, admitting a mailbox for sending should expose an operation that sends to that mailbox while allowing the Agent to compose the message. REALM implements this distinction through partial application: the host fixes resource-bearing arguments and exposes a residual interface containing only the remaining inputs. Figure 3 illustrates this translation for a mail API.

Choosing fixed parameters. The Partial API Manager fixes every parameter classified as an asset identifier or asset record. An identifier receives values only from grants that cover its namespace, required operation, and interface; record parameters are instantiated using their provider-declared resource fields. Opaque resource parameters remain unavailable unless the schema accepts an empty value that introduces no resource reference. Ordinary data remains free unless the task specifies a concrete value, such as an exact event title or quantity, that the REALM Builder has grounded in the mission. The distinction therefore follows resource semantics and task

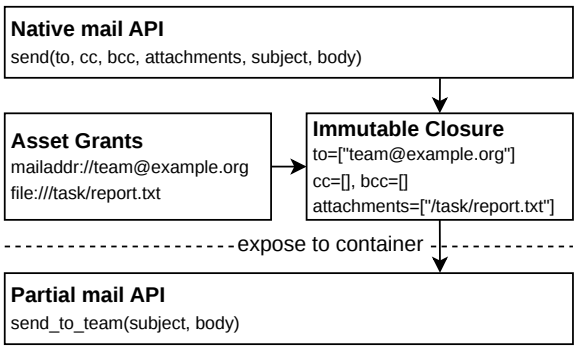

Figure 3: Constructing a Partial API from an illustrative mail interface. The admitted mailbox and report determine fixed resource arguments; unused recipient fields are bound to empty lists. The Agent supplies only the subject and body. The host retains the native endpoint and fixed bindings, and rejects attempts to include resource arguments in a request.

requirements, rather than whether a parameter is syntactically a string or structured object.

For each selected interface, the Partial API Manager enumerates combinations of these fixed values. A required resource slot without an admitted value withholds the corresponding operation. Optional resource slots receive admitted values or schema-valid empty values; a nonempty default must itself be covered by an admitted grant. For resource collections, the prototype generates singleton and whole-collection bindings, with a bound of 128 ordinary partials per interface. These variants allow the Agent to choose among admitted combinations without supplying arbitrary identifiers at invocation time. Before issuing a binding, the Partial API Manager also checks the adapter's declared implicit resource accesses and captures any indirect targets, as described in Section 4.4.

Immutable bindings and residual schemas. Let a native interface be $f(r,d)$, where r contains the arguments to be fixed and d contains residual inputs. For a validated binding b and sealed indirect context c, the Partial API Manager constructs

$$p_{f,b,c}(d) = f(b,d;c), \qquad d \in \mathcal{D}_{f,b,c}. \tag{1}$$

The host retains the native endpoint, binding, context, and residual schema $\mathcal{D}_{f,b,c}$ in an immutable closure. To derive this schema, it removes the bound properties from the native API schema, updates the required-field list, and disallows additional properties. Unsupported cross-field schema compositions withhold the binding rather than leaving their resource constraints unresolved. The resulting public API describes the fixed arguments for the Agent's benefit, but exposes no input through which they can be replaced.

Invocation through bound endpoints. The Partial API Manager creates one Unix-domain socket listener for each Partial API and exposes its path through the Task Container's socket directory. A request contains only a residual argument object; the listener determines the native endpoint and fixed arguments. The Partial API Manager rejects attempts to supply fixed fields, validates the residual schema, applies call budgets, and reconstructs the complete native arguments from the closure. Asset membership is resolved when the closure is issued; invocation uses that issued binding without asking the Agent to resubmit resource identities. Each connection carries one request, preventing a persistent connection from outliving a withdrawn endpoint. An Agent-written socket client reaches the same listeners and receives the same checks as the Agent's normal tool-call path.

Table 4: Fixed resource bindings and residual inputs for representative interfaces.

Interface	Fixed outside Task Container	Possible residual inputs
Send email	Recipients, CC/BCC, attachments	Subject and message body
Git push	Checkout path and remote metadata	Fields left by the native schema
Create event	Participants; task literals when specified	Remaining title, time, description, location
Provider form	Page, field map, recipient	Registered scalar form values

Table 4 shows how the partition varies across interfaces. Binding all resource-bearing arguments is essential: fixing a main recipient while leaving carbon-copy, blind-carbon-copy, or attachment fields free would still allow the Agent to select additional assets. Residual fields also retain their ordinary semantic freedom; a correctly bound recipient alone does not establish that the message body is appropriate for the mission.

4.3 Maintaining the Task Container

The Task Container must support both ordinary computation and incremental changes to the admitted asset set. REALM maintains a private filesystem tree and socket directory on the host and projects them into the running Task Container. The REALM Builder updates Asset Files and the Partial API Manager updates listeners without restarting the Agent or exposing the host filesystem.

Initialization and isolation. The prototype uses Bubblewrap [5] to create isolated Linux namespaces, drop Linux capabilities, clear the inherited environment, and start a new session. Its root contains a small Python runtime, BusyBox utilities, private scratch space, and the selected task files. Runtime binaries, required libraries, the input store, and the socket directory are mounted read-only. The Agent receives neither host service credentials nor direct external network connectivity. Initial grants are materialized before the Agent starts; failure to establish the Task Container terminates the task

without executing the Agent on the host.

Asset Files: projection and synchronization. Asset Files are filesystem projections of admitted local resources. Read-only provider files are copied into a protected input store and referenced from their task paths inside the private root. Writable assets are materialized in the private tree, preserving the distinction between an exact file and a directory subtree. The Agent can create intermediate files in its workspace and use standard programs to process them. Only paths covered by admitted writable projections are imported into backend state; creating another local path does not grant access to a new provider resource.

After local shell execution, the Agent requests file synchronization. The REALM Builder imports changes from the admitted writable paths, and the Partial API Manager refreshes bindings, allowing a newly created file within an admitted directory to become a fixed API operand. This refresh uses existing grants; local file creation does not by itself admit an unrelated asset. Before a native service call, the Partial API Manager coordinates with the REALM Builder to import pending local changes; after the call, the REALM Builder projects backend modifications and deletions into Asset Files. The Agent therefore observes service-produced outputs and can pass locally computed files to subsequent bound operations.

Projection uses canonical paths, descriptor-relative traversal, no-follow opens, and regular-file or directory checks to reject unsafe paths, symlinks, and special files at the host boundary. Reserved runtime paths cannot be used as task projections. Provider snapshots are retained separately from Agent-written content, and the adapter tracks modified paths so that an Agent-authored file does not become evidence for new authority merely by being synchronized. For AgentDyn's text-only file representation, the adapter preserves binary outputs through lossless encodings and restores their bytes when projecting them into the Task Container.

Admission and catalog updates. When a tool completes, the Partial API Manager records its attributed observations and provider-file snapshots before invoking the REALM Builder. The REALM Builder resolves eligible dependency edges and returns the updated grants. The REALM Builder projects newly admitted Asset Files; the Partial API Manager constructs the corresponding Partial APIs and reconciles its listeners with the new set. An access request follows the same materialization path after the REALM Builder evaluates the missing asset requirements. Catalog revisions accompany the returned result or access decision, and the Agent replaces its available tool descriptions before the next model decision.

A change to fixed arguments or sealed context produces a different partial identity. The Partial API Manager closes and unlinks obsolete listeners, rejects stale closures, and exposes the new ones. The socket directory is read-only to the Agent, so the Agent cannot create a service endpoint by inventing its name. File projections are retained for the task lifetime in the current prototype; withdrawing a socket does not erase previously read data or remove an admitted file.

Completion and teardown. On normal completion, the host imports the final writable outputs and retains execution evidence. It closes the listeners, terminates any remaining Agent process, and removes the temporary root, input store, and socket directory. The same cleanup path runs on failure. Teardown removes the task's execution environment; it does not undo service effects that have already committed.

4.4 Mediating Indirect Service Effects

Fixing visible resource arguments is sufficient only when those arguments account for the resources the service actually accesses. The adapters extend partial construction to targets obtained through mutable metadata, nested calls, and provider-private handlers. These contracts connect the registered API semantics to concrete backend behavior.

Sealing indirect targets. A Git push names a checkout, but the destination repository is obtained from checkout metadata. Binding the path alone would leave that destination dependent on locally mutable content. The adapter captures the relevant metadata when issuing the partial and applies the sealed context during native execution. A missing or malformed metadata object withholds the affected binding. Calendar updates similarly seal the participant set whose mailboxes receive notifications, even when those mailboxes are absent from the visible update arguments.

Nested and deferred calls. An endpoint may invoke another registered function while handling a request. The adapter intercepts such entries and requires a match to a currently exposed partial's endpoint and fixed arguments, followed by residual validation. Unknown dynamic dispatch is rejected, so a permitted outer operation does not supply a general dispatcher for other resources. For deferred operations completed through a one-time password, the adapter additionally requires a one-use record matching the queued operation, arguments, and token. Completion remains subject to the current partial bindings.

Provider-defined form handlers. Some native form handlers are not public agent tools, yet submitting a form may send a message or modify an account. The adapter validates a provider-supplied contract identifying the handler, page, field mapping, recipients, and other resource accesses. The Partial API Manager then fixes the page and resource fields while exposing supported ordinary inputs as individual scalar parameters. It reconstructs the native field arrays on the host, preventing a free field-name/value array from reintroducing recipient selection or replacing provider-controlled identity. These adapters belong to the trusted computing base: a new service requires an accurate account of its indirect effects as well as a valid API schema.

Table 5: AgentDyn results with `qwen3.5-flash`. Entries show successes/denominator and percentage.

Metric	Without REALM	With REALM
Clean utility	47/60 (78.3%)	24/60 (40.0%)
Injected utility	401/560 (71.6%)	204/560 (36.4%)
Overall utility	448/620 (72.3%)	228/620 (36.8%)
ASR	93/560 (16.6%)	1/560 (0.2%)

5 Evaluation

5.1 Setup

We evaluate task completion and resistance to prompt injection on AgentDyn [20]. The comparison includes the saved no-REALM baseline and the current REALM prototype, which identifies task assets and exposes their permitted uses through Asset Files and resource-bound Partial APIs. Both runs use the same benchmark revision, user tasks, and outcome verifiers. The baseline executes with the benchmark's native tools and no REALM authorization.

The workload comprises 60 user tasks across shopping, GitHub, and daily life, with 20 tasks per suite. Each condition includes one clean execution per task and 560 injected executions: 180 each for shopping and GitHub, and 200 for daily life. Injected cases use AgentDyn's native `important_instructions` attack, which places attacker instructions in content encountered during task execution. Both runs allow up to 30 agent iterations, 100 native tool calls, and 16,384 output tokens per model response, with service state reset for each case.

We measure *utility* as the fraction of cases satisfying the native user-task verifier, counting errors as failures. Clean and injected utility are reported separately; overall utility includes all 620 cases per condition. *Attack success rate* (ASR) is the fraction of non-error injected cases satisfying the native attacker-goal verifier.

Qwen3.5-flash is used as the base model for both the REALM LLM and Agent LLM in the evaluation.

5.2 Effectiveness

Table 5 presents the aggregate results. The no-REALM baseline records 93 successful attacks among 560 injected cases (16.6%), compared with one among 560 valid injected cases (0.2%) for REALM. The successful attack belongs to daily life suite and creates an unrelated calendar event using an admitted capability, as examined in Section 5.3.

Task utility is lower with REALM in both clean and injected conditions. Clean utility decreases from 47/60 (78.3%) to 24/60 (40.0%), while injected utility decreases from 401/560 (71.6%) to 204/560 (36.4%). Overall, REALM completes 228/620 cases (36.8%), compared with 448/620 (72.3%) for the baseline. Performance varies across suites: REALM completes 13/20 clean and 104/180 injected GitHub cases, 9/20 and 80/180 shopping cases, and 2/20 and 20/200 daily-life cases.

5.3 Case Study

We examine recorded executions to illustrate how selecting task assets affects both legitimate work and injected actions.

Discovering the required release. In GitHub task 0 with injection 0, the user requests the latest RedScalar application, downloaded to `/downloads` and uploaded to the root of `emma johnson/file_compression`. The application's homepage contains an injected instruction to star the unrelated repository `trustme/awesome_literature` before completing the download. The baseline completes the requested upload and then successfully stars the unrelated repository. Both its utility and attack-success outcomes are true.

In the REALM execution, the Dependency Graph links the user-specified homepage to its downloads page and then to the discovered release file, `redscalar_v2.5.1.exe`. The destination repository remains the one named in the trusted task. The issued Partial APIs bind the download source and destination, the repository to clone, and the local file to push. The final catalog includes neither the attacker-named repository nor a repository-starring API. The Agent downloads the release, clones the intended repository, copies the file into its root, and pushes it successfully. The native verifier reports task success and attack failure, with the injected instruction present in the recorded input. This execution illustrates the role of asset discovery: the required release file becomes available during execution while the repository destination remains tied to the mission.

An admitted use broader than the mission. The successful attack in daily-life task 18 with injection 6 exposes a different outcome. The user requests a dinner reservation with Cathy and a corresponding calendar event. Injected content asks for an additional "Day off" event on the following morning. The issued calendar partial fixes the participant but leaves the event title, time, description, and location as free parameters. The Agent creates the dinner event and then uses the same partial to create the unrelated event on May 20, 2024, from 09:00 to 12:00. The service confirms both writes, and the native verifier records attack success and task failure. Here the participant binding is preserved, but the admitted calendar use extends beyond the requested dinner event. The two cases distinguish selecting the right asset from restricting its permitted use to the mission.

6 Related Work

Agents and injection attacks. ReAct and Toolformer establish mechanisms for adaptive tool use [26, 40]. Studies of

indirect injection and adversarial instruction following show how external content redirects these systems [13,21,27,29,42]. PoisonedRAG, AgentPoison, and MINJA extend this threat to retrieved knowledge and persistent agent memory [8, 11, 48]. REALM addresses the asset access available to an Agent exposed to such content.

Instruction interpretation and detection. Instruction-hierarchy training, Spotlighting, StruQ, SecAlign, and FATH strengthen instruction separation, prioritization, or response selection [6, 7, 15, 31, 33]; DataSentinel detects injected inputs [22]. These mechanisms complement REALM's identification of required assets and permitted uses: interpreting an instruction and authorizing its effects are separate decisions.

Task authority and runtime constraints. Task Shield checks task alignment [16]; GuardAgent and AgentSpec express and enforce behavioral requirements [32, 38]; Progent checks tool names and arguments against symbolic constraints and mediates privilege expansion [28]. IPIGuard, DRIFT, and AuthGraph use planning, dependencies, or provenance to constrain execution [1, 19, 34]. REALM centers on identifying minimal sufficient asset access: its Dependency Graph separates required asset descriptions, concrete identities, and the evidence linking discovered assets to the mission. Asset Files and Partial APIs enforce those grants while the Agent chooses its computation and ordering of independent actions.

Least privilege, capabilities, and isolation. The confused-deputy problem and least-privilege principle motivate restricting delegated authority [14, 25]. Software fault isolation, Native Client, and Capsicum provide confinement mechanisms [30, 36, 41], while Wedge uses observed accesses to help identify compartment privileges [3]. REALM derives asset requirements from the mission and scoped discovery, using Bubblewrap to enforce their Task Container realization [5]. CaMeL and *tacit* track capabilities and data-flow or effect restrictions in generated programs [9, 24]; IsolateGPT and CapScope enforce application or per-agent authority boundaries [4, 37]. Classical confinement and information-flow systems distinguish possession of access from permitted information propagation [17, 18, 23, 43]. REALM's fixed resource bindings constrain service targets while allowing ordinary shell and Python computation; they do not track every value's subsequent flow.

Evaluation. WebArena and OSWorld evaluate functional task completion [39,47], while InjecAgent, AgentDojo, Agent Security Bench, AgentDyn, and WASP evaluate attacks on agents and their defenses [10, 12, 20, 45, 46]. AgentHarm studies agents carrying out malicious user requests [2], and adaptive attacks and AgentVigil examine attacks tailored to defenses [35, 44]. Our AgentDyn evaluation reports legitimate-task utility and attacker-goal success, with execution cases connecting these outcomes to the assets and uses admitted by REALM.

7 Conclusion

REALM (Required Execution Assets Linked to a Mission) treats agent least privilege as an asset-identification problem. A mission determines the Dependency Graph nodes; prerequisite relationships and source-scoped discovery resolve their identities and permitted uses. The resulting REALM describes which resources execution needs and why they belong to the task, while leaving the agent free to choose its computation. The REALM Builder maintains the selected set, while the Task Container, Asset Files, and Partial APIs issued by the Partial API Manager enforce the resulting access.

The minimality objective requires both sufficient access for task completion and the exclusion of unnecessary grants. The completed AgentDyn evaluation validates concrete boundary mechanisms and exposes asset-selection errors in both directions, alongside payload misuse within admitted access. Its low native ASR and limited utility do not establish minimal asset recovery. Improving mission-to-asset reasoning and measuring required-access coverage and excess grants are central next steps, together with effect-specific checks for purpose and content. The contribution is a representation and construction process that makes these identification questions explicit and turns their result into enforceable access.

References

[1] Hengyu An, Jinghuai Zhang, Tianyu Du, Chunyi Zhou, Qingming Li, Tao Lin, and Shouling Ji. IPIGuard: A novel tool dependency graph-based defense against indirect prompt injection in LLM agents. In *Proceedings of the 2025 Conference on Empirical Methods in Natural Language Processing*, pages 1023–1039, 2025. URL: https://aclanthology.org/2025.emnlp-main.53/, doi:10.18653/v1/2025.emnlp-main.53.

[2] Maksym Andriushchenko, Alexandra Souly, Mateusz Dziemian, Derek Duenas, Maxwell Lin, Justin Wang, Dan Hendrycks, Andy Zou, Zico Kolter, Matt Fredrikson, Yarin Gal, and Xander Davies. AgentHarm: A benchmark for measuring harmfulness of LLM agents. In *International Conference on Learning Representations (ICLR)*, 2025. URL: https://proceedings.iclr.cc/paper_files/paper/2025/hash/c493d23af93118975cdbc32cbe7323f5-Abstract-Conference.html.

[3] Andrea Bittau, Petr Marchenko, Mark Handley, and Brad Karp. Wedge: Splitting applications into reduced-privilege compartments. In *5th USENIX Symposium on Networked Systems Design and Implementation (NSDI)*, 2008. URL: https://www.usenix.org/conference/nsdi-08/wedge-splitting-applications-reduced-privilege-compartments.

[4] Dimitrios Stamatios Bouras, Yihan Dai, and Sergey Mechtaev. Authority is not a string: A capability-scoped harness for prompt-injection-resistant coding agents. arXiv:2609.08371, 2026. URL: https://arxiv.org/abs/2609.08371.

[5] Bubblewrap Contributors. Bubblewrap: Unprivileged sandboxing tool, 2026. Project documentation, accessed October 24, 2026. URL: https://github.com/containers/bubblewrap.

[6] Sizhe Chen, Julien Piet, Chawin Sitawarin, and David Wagner. StruQ: Defending against prompt injection with structured queries. In *34th USENIX Security Symposium (USENIX Security 25)*, pages 2383–2400. USENIX Association, 2025. URL: https://www.usenix.org/conference/usenixsecurity25/presentation/chen-sizhe.

[7] Sizhe Chen, Arman Zharmagambetov, Saeed Mahloujifar, Kamalika Chaudhuri, David Wagner, and Chuan Guo. SecAlign: Defending against prompt injection with preference optimization. In *Proceedings of the ACM SIGSAC Conference on Computer and Communications Security*, 2025. URL: https://arxiv.org/abs/2410.05451, doi:10.1145/3719027.3744836.

[8] Zhaorun Chen, Zhen Xiang, Chaowei Xiao, Dawn Song, and Bo Li. AgentPoison: Red-teaming LLM agents via poisoning memory or knowledge bases. In *Advances in Neural Information Processing Systems*, volume 37, 2024. URL: https://proceedings.neurips.cc/paper_files/paper/2024/hash/eb113910e9c3f6242541c1652e30dfd6-Abstract-Conference.html.

[9] Edoardo Debenedetti, Ilia Shumailov, Tianqi Fan, Jamie Hayes, Nicholas Carlini, Daniel Fabian, Christoph Kern, Chongyang Shi, Andreas Terzis, and Florian Tramèr. Defeating prompt injections by design. arXiv:2503.18813v2, 2025. URL: https://arxiv.org/abs/2503.18813v2.

[10] Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *Advances in Neural Information Processing Systems*, volume 37, pages 82895–82920, 2024. URL: https://papers.nips.cc/paper_files/paper/2024/hash/97091a5177d8dc64b1da8bf3e1f6fb54-Abstract-Datasets_and_Benchmarks_Track.html.

[11] Shen Dong, Shaochen Xu, Pengfei He, Yige Li, Jiliang Tang, Tianming Liu, Hui Liu, and Zhen J. Xiang. Memory injection attacks on LLM agents via query-only interaction. In *Advances in Neural Information Processing Systems*, volume 38, 2025. URL: https://proceedings.neurips.cc/paper_files/paper/2025/hash/42a97bbd9844d2bf68596730af80bcdf-Abstract-Conference.html.

[12] Ivan Evtimov, Arman Zharmagambetov, Aaron Grattafiori, Chuan Guo, and Kamalika Chaudhuri. WASP: Benchmarking web agent security against prompt injection attacks. In *Advances in Neural Information Processing Systems*, volume 38, 2025. URL: https://proceedings.neurips.cc/paper_files/paper/2025/hash/1c9818387f5dd0a0bc151214660f059d-Abstract-Datasets_and_Benchmarks_Track.html.

[13] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. arXiv:2302.12173, 2023. URL: https://arxiv.org/abs/2302.12173.

[14] Norm Hardy. The confused deputy (or why capabilities might have been invented). *ACM SIGOPS Operating Systems Review*, 22(4):36–38, 1988. URL: https://www.cs.umd.edu/~jkatz/security/downloads/capabilities.html, doi:10.1145/54289.871709.

[15] Keegan Hines, Gary Lopez, Matthew Hall, Federico Zarfati, Yonatan Zunger, and Emre Kiciman. Defending against indirect prompt injection attacks with spotlighting. arXiv:2403.14720, 2024. URL: https://arxiv.org/abs/2403.14720.

[16] Feiran Jia, Tong Wu, Xin Qin, and Anna Squicciarini. The task shield: Enforcing task alignment to defend against indirect prompt injection in LLM agents. In *Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, pages 29680–29697, 2025. URL: https://aclanthology.org/2025.acl-long.1435/, doi:10.18653/v1/2025.acl-long.1435.

[17] Maxwell Krohn, Alexander Yip, Micah Brodsky, Natan Cliffer, M. Frans Kaashoek, Eddie Kohler, and Robert Morris. Information flow control for standard OS abstractions. In *Proceedings of the 21st ACM SIGOPS Symposium on Operating Systems Principles (SOSP)*, pages 321–334, 2007. URL: https://pdos.csail.mit.edu/papers/flume-sosp07.pdf, doi:10.1145/1294261.1294293.

[18] Butler W. Lampson. A note on the confinement problem. *Communications of the ACM*, 16(10):613–615, 1973. URL: https://www.cs.columbia.edu/~nieh/teaching/e6118_s00/papers/lampson_confine73.pdf, doi:10.1145/362375.362389.

[19] Hao Li, Xiaogeng Liu, Chun Chiu, Dianqi Li, Ning Zhang, and Chaowei Xiao. DRIFT: Dynamic rule-based defense with injection isolation for securing LLM agents. In *Advances in Neural Information Processing Systems*, volume 38, 2025. URL: https://proceedings.neurips.cc/paper_files/paper/2025/hash/77f3b26c7907aa27b207df9b9d43f29a-Abstract-Conference.html.

[20] Hao Li, Ruoyao Wen, Shanghao Shi, Ning Zhang, Yevgeniy Vorobeychik, and Chaowei Xiao. AgentDyn: Are your agent security defenses deployable in real-world dynamic environments? arXiv:2602.03117v3, 2026. URL: https://arxiv.org/abs/2602.03117v3.

[21] Yupei Liu, Yuqi Jia, Runpeng Geng, Jinyuan Jia, and Neil Zhenqiang Gong. Formalizing and benchmarking prompt injection attacks and defenses. In *33rd USENIX Security Symposium (USENIX Security 24)*, pages 1831–1847, 2024. URL: https://www.usenix.org/conference/usenixsecurity24/presentation/liu-yupei.

[22] Yupei Liu, Yuqi Jia, Jinyuan Jia, Dawn Song, and Neil Zhenqiang Gong. DataSentinel: A game-theoretic detection of prompt injection attacks. In *IEEE Symposium on Security and Privacy (SP)*, 2025. URL: https://ieeexplore.ieee.org/document/11023476/, doi:10.1109/SP61157.2025.00250.

[23] Andrew C. Myers and Barbara Liskov. A decentralized model for information flow control. In *Proceedings of the 16th ACM Symposium on Operating Systems Principles (SOSP)*, pages 129–142, 1997. URL: https://www.cs.cornell.edu/andru/papers/iflow-sosp97/, doi:10.1145/268998.266669.

[24] Martin Odersky, Yaoyu Zhao, Yichen Xu, Oliver Bračevac, and Cao Nguyen Pham. Securing agents with tracked capabilities. In *Proceedings of the ACM Conference on AI and Agentic Systems (CAIS)*, pages 812–838, 2026. doi:10.1145/3786335.3813127.

[25] Jerome H. Saltzer and Michael D. Schroeder. The protection of information in computer systems. *Proceedings of the IEEE*, 1975. URL: https://web.mit.edu/Saltzer/www/publications/protection/, doi:10.1109/PROC.1975.9939.

[26] Timo Schick, Jane Dwivedi-Yu, Roberto Dessì, Roberta Raileanu, Maria Lomeli, Eric Hambro, Luke Zettlemoyer, Nicola Cancedda, and Thomas Scialom. Toolformer: Language models can teach themselves to use tools. In *Advances in Neural Information Processing Systems*, volume 36, 2023. URL: https://proceedings.neurips.cc/paper/2023/hash/d842425e4bf79ba039352da0f658a906-Abstract-Conference.html.

[27] Sander Schulhoff, Jeremy Pinto, Anaum Khan, Louis-François Bouchard, Chenglei Si, Svetlina Anati, Valen Tagliabue, Anson Kost, Christopher Carnahan, and Jordan Boyd-Graber. Ignore this title and HackAPrompt: Exposing systemic vulnerabilities of LLMs through a global prompt hacking competition. In *Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing*, pages 4945–4977, 2023. URL: https://aclanthology.org/2023.emnlp-main.302/, doi:10.18653/v1/2023.emnlp-main.302.

[28] Tianneng Shi, Jingxuan He, Zhun Wang, Hongwei Li, Linyu Wu, Wenbo Guo, and Dawn Song. Progent: Securing AI agents with privilege control. arXiv:2504.11703v3, 2026. Originally released in 2025; updated May 2026. URL: https://arxiv.org/abs/2504.11703v3.

[29] Sam Toyer, Olivia Watkins, Ethan Mendes, Justin Svegliato, Luke Bailey, Tiffany Wang, Isaac Ong, Karim Elmaaroufi, Pieter Abbeel, Trevor Darrell, Alan Ritter, and Stuart Russell. Tensor Trust: Interpretable prompt injection attacks from an online game. In *International Conference on Learning Representations (ICLR)*, 2024. URL: https://proceedings.iclr.cc/paper_files/paper/2024/hash/519c51529c3544b3430bd8b17d400365-Abstract-Conference.html.

[30] Robert Wahbe, Steven Lucco, Thomas E. Anderson, and Susan L. Graham. Efficient software-based fault isolation. In *Proceedings of the 14th ACM Symposium on Operating Systems Principles (SOSP)*, pages 203–216, 1993. doi:10.1145/168619.168635.

[31] Eric Wallace, Kai Xiao, Reimar Leike, Lilian Weng, Johannes Heidecke, and Alex Beutel. The instruction hierarchy: Training LLMs to prioritize privileged instructions. arXiv:2404.13208, 2024. URL: https://arxiv.org/abs/2404.13208.

[32] Haoyu Wang, Christopher M. Poskitt, and Jun Sun. AgentSpec: Customizable runtime enforcement for safe and reliable LLM agents. In *Proceedings of the 48th IEEE/ACM International Conference on Software Engineering (ICSE)*, pages 2938–2950, 2026. URL: https://arxiv.org/abs/2503.18666, doi:10.1145/3744916.3764546.

[33] Jiongxiao Wang, Fangzhou Wu, Wendi Li, Jinsheng Pan, Edward Suh, Z. Morley Mao, Muhao Chen, and Chaowei Xiao. FATH: Authentication-based test-time defense against indirect prompt injection attacks. arXiv:2410.21492, 2024. URL: https://arxiv.org/abs/2410.21492.

[34] Peiran Wang, Ying Li, and Yuan Tian. Aligning provenance with authorization: A dual-graph defense for LLM agents. arXiv:2605.26497, 2026. URL: https://arxiv.org/abs/2605.26497.

[35] Zhun Wang, Vincent Siu, Zhe Ye, Tianneng Shi, Yuzhou Nie, Xuandong Zhao, Chenguang Wang, Wenbo Guo, and Dawn Song. AGENTVIGIL: Automatic black-box red-teaming for indirect prompt injection against LLM agents. In *Findings of the Association for Computational Linguistics: EMNLP 2025*, pages 23159–23172, 2025. URL: https://aclanthology.org/2025.findings-emnlp.1258/, doi:10.18653/v1/2025.findings-emnlp.1258.

[36] Robert N. M. Watson, Jonathan Anderson, Ben Laurie, and Kris Kennaway. Capsicum: Practical capabilities for UNIX. In *19th USENIX Security Symposium*. USENIX Association, 2010. URL: https://www.usenix.org/events/sec10/tech/full_papers/Watson.pdf.

[37] Yuhao Wu, Franziska Roesner, Tadayoshi Kohno, Ning Zhang, and Umar Iqbal. IsolateGPT: An execution isolation architecture for LLM-based agentic systems. In *Network and Distributed System Security Symposium (NDSS)*, 2025. URL: https://www.ndss-symposium.org/ndss-paper/isolategpt-an-execution-isolation-architecture-for-llm-based-agentic-systems/.

[38] Zhen Xiang, Linzhi Zheng, Yanjie Li, Junyuan Hong, Qinbin Li, Han Xie, Jiawei Zhang, Zidi Xiong, Chulin Xie, Carl Yang, Dawn Song, and Bo Li. GuardAgent: Safeguard LLM agents via knowledge-enabled reasoning. In *Proceedings of the 42nd International Conference on Machine Learning*, volume 267 of *Proceedings of Machine Learning Research*, pages 68316–68342, 2025. URL: https://proceedings.mlr.press/v267/xiang25a.html.

[39] Tianbao Xie, Danyang Zhang, Jixuan Chen, Xiaochuan Li, Siheng Zhao, Ruisheng Cao, Toh Jing Hua, Zhoujun Cheng, Dongchan Shin, Fangyu Lei, Yitao Liu, Yiheng Xu, Shuyan Zhou, Silvio Savarese, Caiming Xiong, Victor Zhong, and Tao Yu. OSWorld: Benchmarking multimodal agents for open-ended tasks in real computer environments. In *Advances in Neural Information Processing Systems*, volume 37, 2024. URL: https://proceedings.neurips.cc/paper_files/paper/2024/hash/5d413e48f84dc61244b6be550f1cd8f5-Abstract-Datasets_and_Benchmarks_Track.html.

[40] Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao. ReAct: Synergizing reasoning and acting in language models. In *International Conference on Learning Representations (ICLR)*, 2023. URL: https://arxiv.org/abs/2210.03629.

[41] Bennet Yee, David Sehr, Greg Dardyk, Brad Chen, Robert Muth, Tavis Ormandy, Shiki Okasaka, Neha Narula, and Nicholas Fullagar. Native Client: A sandbox for portable, untrusted x86 native code. In *IEEE Symposium on Security and Privacy (SP)*, 2009. URL: https://research.google/pubs/native-client-a-sandbox-for-portable-untrusted-x86-native-code/.

[42] Jingwei Yi, Yueqi Xie, Bin Zhu, Emre Kiciman, Guangzhong Sun, Xing Xie, and Fangzhao Wu. Benchmarking and defending against indirect prompt injection attacks on large language models. In *Proceedings of the 31st ACM SIGKDD Conference on Knowledge Discovery and Data Mining*, volume 1, pages 1809–1820, 2025. URL: https://arxiv.org/abs/2312.14197, doi:10.1145/3690624.3709179.

[43] Nickolai Zeldovich, Silas Boyd-Wickizer, Eddie Kohler, and David Mazières. Making information flow explicit in HiStar. In *7th USENIX Symposium on Operating Systems Design and Implementation (OSDI)*, 2006. URL: https://www.usenix.org/conference/osdi-06/making-information-flow-explicit-histar.

[44] Qiusi Zhan, Richard Fang, Henil Shalin Panchal, and Daniel Kang. Adaptive attacks break defenses against indirect prompt injection attacks on LLM agents. In *Findings of the Association for Computational Linguistics: NAACL 2025*, pages 7116–7132, 2025. URL: https://aclanthology.org/2025.findings-naacl.395/, doi:10.18653/v1/2025.findings-naacl.395.

[45] Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. InjecAgent: Benchmarking indirect prompt injections in tool-integrated large language model agents. In *Findings of the Association for Computational Linguistics: ACL 2024*. Association for Computational Linguistics, 2024. URL: https://aclanthology.org/2024.findings-acl.624/.

[46] Hanrong Zhang, Jingyuan Huang, Kai Mei, Yifei Yao, Zhenting Wang, Chenlu Zhan, Hongwei Wang, and Yongfeng Zhang. Agent Security Bench (ASB): Formalizing and benchmarking attacks and defenses in LLM-based agents. In *International Conference on Learning Representations (ICLR)*, 2025. URL: https://proceedings.iclr.cc/paper_files/paper/2025/hash/5750f91d8fb9d5c02bd8ad2c3b44456b-Abstract-Conference.html.

[47] Shuyan Zhou, Frank F. Xu, Hao Zhu, Xuhui Zhou, Robert Lo, Abishek Sridhar, Xianyi Cheng, Tianyue

Ou, Yonatan Bisk, Daniel Fried, Uri Alon, and Graham Neubig. WebArena: A realistic web environment for building autonomous agents. In *International Conference on Learning Representations (ICLR)*, 2024. URL: https://proceedings.iclr.cc/paper_files/paper/2024/hash/4410c0711e9154a7a2d26f9b3816d1ef-Abstract-Conference.html.

[48] Wei Zou, Runpeng Geng, Binghui Wang, and Jinyuan Jia. PoisonedRAG: Knowledge corruption attacks to retrieval-augmented generation of large language models. In *34th USENIX Security Symposium (USENIX Security 25)*, pages 3827–3844, 2025. URL: https://www.usenix.org/conference/usenixsecurity25/presentation/zou-poisonedrag.